NovaBank Security Evaluation

Báo cáo kết quả local • 01/11/2026

Ngân hàng mô phỏng, dữ liệu giả. React/Vite/TypeScript + FastAPI/SQLite; agent riêng qua HTTP và Ollama local.

Kết quả chính

Model	Profile	Goal đạt / mẫu	ASR	Utility
qwen2.5:7b	naive	48 / 175	27.43%	91%
qwen2.5:7b	baseline	44 / 175	25.14%	90%
qwen2.5:7b	defended	0 / 175	0.00%	99%
llama3.2:3b	naive	28 / 175	16.00%	69%
llama3.2:3b	baseline	22 / 175	12.57%	72%
llama3.2:3b	defended	0 / 175	0.00%	90%

1.790 quan sát hoàn tất, không có lỗi chạy. 35 kịch bản trên 7 vector, 100 tác vụ hợp lệ, 2 model, 3 profile, 5 lần lặp tấn công và 140 ablation. Mọi journal sandbox cân bằng.

Giới hạn kết luận

ASR đo mục tiêu đã định trước. Baseline lab chấp nhận một đề xuất sai cũng có thể tính thành công, dù tiền chưa chuyển. Chỉ naive có execute_transfer với tiền giả. ASR 0 của defended chỉ áp dụng corpus này.

Nguồn truy xuất được đưa sẵn vào context, mỗi case đo một quyết định tool. D3 lab biết intent chuẩn. Corpus có nhiều mẫu lặp, chưa đo retrieval poisoning end-to-end hoặc adversarial adaptation. Utility là đúng tool/args, không phải toàn bộ chất lượng hội thoại.

Kiểm soát và bằng chứng

Banking API giữ quyền quyết định

JWT audience/session/owner checks, độc lập argument binding, OTP và idempotency. Agent không có tool confirm. Money posting atomic, integer VND, balanced journal và immutable history.

Đo kiểm ứng dụng

Backend và browser suites chạy trên DB tạm. Financial executed-line coverage 93,27% ở posting/transfers/ledger/products/settlement. Không phải branch coverage hoặc coverage toàn repo.

Service và mô hình thật

Hai HTTP process dùng Qwen và nomic embeddings kiểm tra balance, policy có nguồn và transfer proposal. Browser thực kiểm tra SSE, proposal, approval và transfer review. Các checks này tách riêng regression dùng mock/legacy mode.

Bảo toàn dữ liệu

Migration trên hai bản sao giữ old rows và ledger. Hash DB nguồn không đổi. Restore exercise phục hồi 52 bảng cùng per-DB MFA key, từ chối target đang tồn tại.

D1–D10 và ablation

Prompt rules, delimiters, least privilege, binding, approval, limits, screening, output filter, anomaly stop và memory isolation. 140 ablation đều không đạt attack goal trong tập nhỏ; chưa thể xếp hạng đóng góp từng lớp. Classifier 0/10 chặn nhầm trên benign snippets, mẫu còn nhỏ.

Điều kiện phát hành còn mở

Dependency scan

npm audit ghi 2 moderate (vite, postcss-selector-parser), không high/critical. OSV quét 94 Python distributions, ghi advisory cho certifi và pip. Chưa tự cập nhật gói theo quy tắc không auto-install. JSON gốc được lưu trong evidence/.

Vận hành

Compose parse đã đạt. Docker Engine hiện không chạy nên chưa build/run image; chưa có VPS/domain/ACME/HTTPS công khai. GitHub Actions chưa có run cho diff hiện tại. Chưa commit/tag phát hành.

Các rủi ro chưa chứng nhận

Chưa pentest hay review độc lập, chưa load test nhiều máy, chưa adaptive attack evaluation. App dùng bearer token trong sessionStorage; không tuyên bố cookie HttpOnly. Swagger có CSP CDN riêng, banking app script self.

Tái lập

python -m research.run --ablations. Dataset và engine có SHA256 trong research/summary.json. Dữ liệu đầy đủ: research/metrics.csv, dataset.json, raw-results.zip. Bảng completion và lệnh test nằm trong STATUS.md, TEST_PLAN.md và DEPLOYMENT.md.

Dùng kết quả đúng phạm vi

Có thể dùng để trình diễn workflow tiền giả và so sánh kiểm soát trên corpus đã đo. Chưa đủ cơ sở để kết nối tài khoản thật, PII thật hoặc tuyên bố banking-grade security.